

LAB 01

FinCore Bank - Kullanıcı Yetkileri ve Access Review Denetimi

Zorluk: Başlangıç • Tahmini süre: 30-60 dakika • Rolünüz: IT Auditor

1. HİKÂYE

Sektör Dijital bankacılık	Ölçek 2.450 çalışan, 38 şube
BT ortamı AD, CoreBank, Oracle, ServiceNow, Azure	Kritik sistemler CoreBank, SWIFT Gateway, kredi ve müşteri veri platformu

FinCore Bank, mobil müşteri sayısındaki hızlı artış sonrasında kimlik ve erişim yönetimi süreçlerini merkezileştirmiştir. İnsan Kaynakları, Active Directory ve bankacılık uygulamalarının kullanıcı kayıtları gecelik entegrasyonlarla eşleştirilmektedir. İç Denetim Komitesi son çeyrekte iki ayrıcalıklı hesabın sahibinin belirlenemediğini fark etmiş, Bilgi Güvenliği ekibi ise dönemsel erişim gözden geçirmesinin tamamlandığını bildirmiştir. Siz, yıl sonu denetim planı kapsamında kullanıcı yaşam döngüsü ve access review sürecini incelemek üzere görevlendirildiniz.

2. SİZE VERİLEN GÖREV

01.01.2026-30.06.2026 dönemindeki kullanıcı erişimlerinin tasarısını ve çalışma etkinliğini değerlendirin. Bulgularınızı yalnızca verilen materyalle kesinleştirmeyin; kanıt yeterliliğini ayrıca tartışın.

3. OLAYLAR VE KANITLAR

E-01 | Politika IAM-04 / madde 6.2

İşten ayrılan kullanıcı erişimleri İK bildiriminin ardından en geç 4 saat içinde kapatılır. Ayrıcalıklı erişimler üç ayda bir, diğer erişimler altı ayda bir sistem sahibi tarafından gözden geçirilir.

E-02 | İK ayrılış listesi - örneklem

Selin Akay: 03.03.2026; Burak Erdem: 18.04.2026; Deniz Acar: 02.05.2026. AD çıktısında Selin hesabı aynı gün kapalı, Burak hesabı 21.04'te kapalı, Deniz hesabı aktif görünmektedir. Uygulama sahibi Deniz'in danışman olarak devam ettiğini söylemiştir; sözleşme sunulmamıştır.

E-03 | Dormant hesap raporu

90 günü aşan 47 hesap vardır. 39'u teknik servis hesabı olarak etiketlidir. Sekiz kişisel hesaptan üçünün son oturumu 2024'tedir. IAM yöneticisi raporun aylık üretildiğini, kapatma kararını sistem sahiplerine bıraktıklarını belirtmiştir.

E-04 | Ayrıcalıklı erişim dökümü

DBA_ADMIN: 14 üye; DOMAIN ADMINS: 9 üye; CoreBank-SUPERUSER: 22 üye. İki hesap 'svc_batch' ve 'admin_temp' ortak posta kutusuna bağlıdır. admin_temp için talep kaydı bulunamamıştır.

LAB 01

FinCore Bank - Kullanıcı Yetkileri ve Access Review Denetimi

Zorluk: Başlangıç • Tahmini süre: 30-60 dakika • Rolünüz: IT Auditor

3. OLAYLAR VE KANITLAR - DEVAM

E-05 | Access review kanıtı

CoreBank sahibi tarafından imzalanmış PDF'de 612 kullanıcının tamamı 'uygun' olarak işaretlidir. Dosya 7 dakikada oluşturulmuş görünmektedir. Kaynak popülasyonun kim tarafından ve hangi tarihte çekildiği belgelenmemiştir.

E-06 | E-posta

Konu: Haziran erişim onayı. 'Listeyi kontrol ettim. Satış ekibindeki arkadaşların eski departman rolleri iş sürekliliği için şimdilik kalsın. Bir sonraki dönemde temizleriz.' - Perakende Bankacılık Müdürü

E-07 | Normal çalışan örnekleri

Seçilen 20 yeni çalışanın 18'inde yönetici ve sistem sahibi onayı vardır. İki kayıta sistem sahibi onayı eksiktir. Beş görev değişikliğinden üçünde eski rol aynı gün kaldırılmıştır.

4. ÖĞRENCİNİN GÖREVLERİ

1. En önemli riskleri ve etkilenen kritik varlıkları belirleyin.
2. Kullanıcı yaşam döngüsü ile access review kontrollerini ayrı değerlendirin.
3. Deniz Acar hesabı hakkında sonuca varmadan önce hangi ek kanıtları istersiniz?
4. PDF access review kanıtının güvenilirliğini ve popülasyon bütünlüğünü tartışın.
5. Ortak ve dormant hesapları önem derecesine göre sıralayın.
6. En önemli konuyu profesyonel audit finding formatında yazın.

5. TESLİM EDİLMESİ BEKLENEN ÇIKTI

- 3 temel risk ve gerekçeli risk seviyesi
- En az 3 kontrol değerlendirmesi
- Ek kanıt talep listesi
- 1 profesyonel denetim bulgusu
- 3-5 cümlelik yönetici özeti

ÇALIŞMANIZI TAMAMLADINIZ MI?

Bu vaka çalışmasının tek bir doğru cevabı olmayabilir. Önemli olan; riskleri nasıl değerlendirdiğiniz, kanıtları nasıl yorumladığınız ve vardığınız sonucu nasıl savunduğunuzdur.

Çalışmanızı tamamladıktan sonra çıktınızı:

volkan@grcustasi.com
adresine gönderebilirsiniz.

Gönderdiğiniz çalışmayı inceleyerek size geri dönüş sağlayacağım.

- Volkan Güler, CISA, CISM
GRC Ustası